APPENDIX

SUPPLEMENTARY EXPERIMENTAL RESULTS

In TABLE I, NOP (Number of Payloads) indicates the total number of attack samples constructed by the five mainstream penetration testing tools. DFR (Defense Rate) reflects the proportion of attack requests successfully intercepted by DPSSX (a higher value indicates better protection performance).

TABLE I
PERFORMANCE COMPARISON OF VULNERABILITY SCANNING TOOLS

Apps	**NOP**					**DFR(%)**
	Sqlmap	**JSQLi**	**SSQL**	**DSSS**	**BruteXSS**	
Dvwa	2733	207	286	257	477	100
Pikachu	4871	0	590	649	127	100
Bwapp	8913	713	184	204	102	100
Sqlilabs	15552	1102	873	2002	0	100
Schoolmate	9566	2671	2855	2941	207	100
Faqforge	9002	257	579	648	170	100
Wackopicko	314	12	68	92	0	100
Myblog	207	0	101	129	0	100
Webchess	3532	198	924	1250	114	100
COVID	2683	0	629	783	204	100
Doctormms	1688	1	652	1439	385	100
Petshop	307	72	323	457	0	100
WebGoatPHP	0	0	0	0	347	100
Alpha	849	116	826	28	106	100
Prestashop	7005	526	579	875	190	100
WordPress	1657	470	593	356	197	100
AbanteCart	3172	401	318	434	331	100
OpenCart	5214	1523	2105	3847	806	100
ESPCMS	1687	257	824	479	0	100
AShop	1102	410	631	695	0	100

In TABLE II, NOR refers to the number of requests sent to the web application. "ART_N" represents the average response time required by the original web application. "ART_Y" indicates the average response time required after using our method. "TD" is the time difference between "ART_Y" and "ART_N".

TABLE II
COMPARATIVE ANALYSIS OF RESPONSE TIME

Apps	**ART_N[s](NOR)**	**ART_Y[s](NOR)**	**TD(s)**	**PD(%)**
Dvwa	0.344(1103)	0.326(968)	-0.018	-5.23
Pikachu	1.245(480)	0.845(408)	-0.400	-32.12
Bwapp	2.53(1052)	0.497(682)	-2.033	-80.35
Sqlilabs	0.32(690)	0.318(218)	-0.002	-0.62
Schoolmate	0.865(253)	0.437(947)	-0.428	-49.47
Faqforge	0.35(8002)	0.36(1451)	0.010	2.85
Wackopicko	0.786(54)	0.806(25)	0.020	2.54
Myblog	0.412(428)	0.404(311)	-0.008	-1.94
Webchess	2.565(365)	0.487(587)	-2.078	-81.01
COVID	2.85(81)	0.854(169)	-1.996	-70.03
Doctormms	0.406(460)	0.372(445)	-0.034	-8.37
Petshop	0.332(812)	0.298(798)	-0.034	-10.24
WebGoatPHP	0.264(336)	0.288(153)	0.024	9.09
Alpha	1.561(60)	0.756(86)	-0.805	-51.56
Prestashop	1.758(326)	0.405(188)	-1.353	-76.96
WordPress	1.614(411)	0.953(284)	-0.661	-40.95
AbanteCart	2.375(610)	1.282(364)	-1.093	-46.02
OpenCart	1.857(826)	1.622(683)	-0.235	-12.65
ESPCMS	1.495(179)	1.361(152)	-0.134	-8.96
AShop	1.293(93)	1.262(104)	-0.031	-2.40

TABLE III presents the detection results of eight previous tools, SQLPsdem [22], and DPSSX on these benchmark test cases. Among them, the results of [3], [10], [11], [21], [69] are sourced from DIGLOSSIA [19] and SEPTIC [17]. Except for SEPTIC, SQLPsdem, and DPSSX, all other tools did not analyze BroNIEs, marked as "-".

TABLE III
THE DETECTION RESULTS OF DPSSX ON CIAO AND BRONIE TEST CASES

Methods	**CIAOs**											**BroNIEs**				
	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16
Ray and Ligatti [32] [68]	Yes	Yes	Yes	No	Yes	Yes	No	Yes	Yes	Yes	No	No	Yes	Yes	Yes	Yes
Halfond et al. [10]	Yes	Yes	Yes	No	No	No	No	No	No	No	Yes	-	-	-	-	-
Nguyen et al. [11]	Yes	Yes	Yes	No	No	No	No	No	No	No	Yes	-	-	-	-	-
Xu et al. [69]	Yes	Yes	Yes	No	No	No	No	No	No	No	Yes	-	-	-	-	-
SQLCHECK [21]	Yes	No	No	Yes	No	No	No	No	No	No	No	-	-	-	-	-
CANDID [3]	Yes	Yes	Yes	No	No	No	Yes	No	No	No	Yes	-	-	-	-	-
DIGLOSSIA [19]	Yes	Yes	Yes	No	Yes	Yes	No	Yes	Yes	No	No	-	-	-	-	-
SEPTIC [17]	Yes	Yes	Yes	No	Yes	Yes	No	Yes	Yes	No	No	No	-	Yes	Yes	-
SQLPsdem [22]	Yes	Yes	Yes	No	Yes	Yes	No	Yes	Yes	No	No	No	Yes	Yes	Yes	Yes
DPSSX	Yes	Yes	Yes	No	Yes	Yes	No	Yes	Yes	No	No	No	Yes	Yes	Yes	Yes

TABLE IV
REMAINING FNS IDENTIFIED BY DPSSX BUT MISSED BY SQLPSDEM

Apps.	SQL Query	Injection position	File Location (Vul. num)	Type	Reason
DVWA	SELECT * FROM 'users' WHERE user='$user' AND password='$pass';	$user	∼\login.php	FO	FN
	SELECT * FROM 'users' WHERE user='$user' AND password='$pass';	$pass	∼\login.php	FO	FN
	SELECT table_schema, table_name, create_time FROM information_schema.tables WHERE table_schema='$_DVWA['db_database']' AND table_name='users' LIMIT 1	$_DVWA['db_database']	∼\login.php	FO	FN
Sqlilabs	SELECT * FROM users WHERE id=$id LIMIT 0,1	$id	∼\Less-2\index.php	FO	FN
	SELECT * FROM users WHERE id=$id LIMIT 0,1	$id	∼\Less-39\index.php	FO	FN
Webchess	INSERT INTO pieces (gameID, msgType, msgStatus, destination) VALUES ("'.$_SESSION['gameID'].", 'draw', 'request', "'".$opponentColor."'"	$_SESSION['gameID']	∼\chessdb.php	SO	FN
	SELECT * FROM communication WHERE commID = $messageID	$messageID	∼\viewmessage.php	FO	FN
	INSERT INTO communication (gameID, fromID, toID, title, text, postDate, expireDate, ack, commType) VALUES ($mGame, $fromPerson, $toPerson, '$msgtitle', '$msgtext', NOW(), NULL, '0', '$msgtype');	$toPerson	∼\sendmessage.php	FO	FN

TABLE IV lists the remaining FNs of SQLPsdem.